Republic of the Philippines

BATANGAS STATE UNIVERSITY

The National Engineering University

Alangilan Campus

Batangas City, Batangas, Philippines 4200

DUAL-LAYERED DEFENSE FOR ONLINE BANKING AND TRANSACTIONS:

DESIGNING A JAVA CARD AS MFA AND REAL-TIME THREAT ALERT USING AI

A Research Study

Presented to the Faculty of the

College of Engineering

Department of Computer Engineering

In Partial Fulfillment of the Requirements

for the Degree of Bachelor of Science in Computer Engineering

By:

Dimaano, Harry V.

Lagarde, Richard

Samson, Dirk P.

May 2026

CHAPTER 1

INTRODUCTION

I. Background of the Study

Online banking has reshaped how people manage money. Transactions that once required a bank visit now happen in seconds from a phone. That convenience is real, and so are the consequences: as digital finance became routine, so did the attacks targeting it. Phishing campaigns, credential theft, and man-in-the-middle (MiTM) interception have grown more sophisticated alongside the platforms they target, not because security teams are asleep, but because the threat surface expanded faster than the defenses covering it.

The authentication systems most banks still deploy reflect an earlier era of risk. Passwords, PINs, and one-time passwords sent over SMS or email were designed when the primary concern was unauthorized physical access, not remote digital compromise. Karim et al. (2024) found that these methods now form the weakest link in online banking security, precisely because their ubiquity makes them predictable targets. Haruna et al. (2022) documented how unencrypted data channels and weak third-party integrations enabled the 2016 Bangladesh Bank SWIFT attack, a breach that exposed $81 million and illustrated what happens when MFA exists on paper but not in practice.

The Philippines has its own illustration of this problem. The National Privacy Commission (NPC, 2023) investigated a wave of unauthorized GCash transactions traced to a phishing scheme disguised as an online gambling platform. Victims did not fail to use security features; the features themselves failed to stop an attacker who understood how to work around them. The Philippine government responded with the Anti-Financial Account Scamming Act (AFASA), signed in 2026, which begins phasing out SMS-based OTPs in favor of stronger authentication. The law is directionally correct, but the Senate of the Philippines has indicated the transition currently points toward biometric authentication—a technology that carries its own well-documented risks.

Biometric data, unlike a password, cannot be changed once it is stolen. Prakasha and Sumalatha (2025) reviewed privacy-preserving approaches in biometric systems and

concluded that once a biometric template is compromised, the user has no recovery path. A password can be reset; a fingerprint cannot. Furthermore, biometric verification on a mobile device depends on that device's own security posture, meaning a compromised operating environment can intercept and relay biometric-derived tokens before they reach a trusted verification process.

Java Card technology offers a different architecture. A JavaCard is a programmable smart card with a tamper-resistant Secure Element that executes cryptographic operations in isolation from the host device. Private keys generated inside the card never leave it. An attacker who controls the phone, the network, or the server still cannot extract the key material if it was properly provisioned. This property, non-exportability of the private key, is what distinguishes hardware-backed authentication from every software-based alternative currently in widespread use.

This study combines that hardware foundation with an AI-driven threat detection layer. The system uses an NFC-enabled ECDSA P-256 JavaCard as a FIDO2-compliant second factor and embeds a CNN-LSTM phishing detection model inside a Flutter-based mobile banking application. Together, these two layers address what single-layer systems cannot: they protect against both credential interception at the protocol level and social engineering at the application level. The result is a dual-layered defense that meets the technical direction of AFASA, operates on consumer-grade hardware, and does not require users to trust a biometric enrollment they cannot revoke.

II. Statement of the Problem

Despite the availability of multi-factor authentication, online banking users in the Philippines and globally remain vulnerable to credential compromise. The core problem is structural: current MFA implementations depend on network-transmitted secrets or biometric data stored outside a tamper-resistant boundary, both of which can be intercepted or stolen without the user's knowledge.

Specifically, this study addresses the following:

1. Existing SMS- and email-based OTP systems are susceptible to SIM swapping, SS7 protocol exploitation, and phishing interception, making them inadequate as standalone second factors for high-value financial transactions.
2. Biometric authentication, while convenient, is irreversible once compromised and depends on the security of the host device rather than an isolated hardware boundary.
3. Mobile banking applications currently lack real-time, on-device detection of phishing URLs and fraudulent SSL/TLS certificates, leaving users exposed to social engineering at the application layer.
4. No cost-accessible hardware authentication solution exists that meets FIDO2 compliance requirements, integrates with NFC-capable Android devices, and includes embedded AI-driven threat alerting in a single prototype.

III. Objectives of the Study

The main objective of this study is to design and develop a dual-layered defense system for online banking and transactions by implementing a FIDO2-compliant NFC Java Card as a hardware MFA token and an AI-driven real-time threat alert module embedded within a mobile banking application.

Specifically, this study aims to:

5. Design and implement a Java Card capable of securely generating and signing authentication challenges using ECDSA P-256, with the private key permanently stored in a non-exportable format within the card's Secure Element.
6. Develop a cross-platform mobile application using Flutter/Dart, connected to Firebase, that supports NFC-based FIDO2 authentication and manages user registration and session state.
7. Integrate an AI threat detection engine that classifies URLs and evaluates SSL/TLS certificate validity in real time to identify phishing and MiTM attempts during active banking sessions.

8. Apply STRIDE-based threat modeling to the complete system architecture and document the prototype's resistance to spoofing, tampering, repudiation, information disclosure, denial of service, and privilege escalation.

IV. Significance of the Study

This research produces a working prototype and documented methodology that holds practical value for several groups.

Financial institutions stand to gain a concrete proof-of-concept showing how hardware-backed FIDO2 authentication can be deployed at consumer scale using accessible hardware. The system demonstrates that strong cryptographic authentication does not require expensive proprietary infrastructure.

End users, particularly Filipinos affected by rising rates of digital financial fraud, benefit from a solution that provides hardware-level protection against phishing and credential theft without requiring them to surrender biometric data they cannot replace.

Government and regulatory bodies, including the Bangko Sentral ng Pilipinas (BSP) and the NPC, will find in this study a technical implementation that aligns with AFASA's mandate for stronger authentication while remaining cost-accessible for broad adoption across the banking sector.

Academic researchers in cybersecurity and FinTech gain a documented integration of cryptographic hardware with applied machine learning, with full methodology, datasets, and threat modeling documentation available for replication and extension.

V. Scope and Limitations

This study is scoped to the design, development, and prototype testing of a dual-layered authentication system. The hardware component consists of a Feitian FT-JCOS Java Card (A40CR) programmed with a FIDO2-compliant applet. The software component is a Flutter/Dart mobile application with Firebase backend services and an embedded CNN-LSTM URL classifier. All testing is performed on NFC-capable Android smartphones.

The prototype demonstrates login and basic transaction verification scenarios. It does not integrate with any live banking infrastructure; all transaction scenarios are simulated using controlled environments and synthetic or publicly available datasets. The phishing detection module is trained on the PhishTank and UCI phishing datasets and validated on held-out test splits from the same sources.

The system is not tested on iOS devices due to NFC API restrictions on that platform in the current implementation. Relay attack testing uses simulated NFC capture data rather than purpose-built relay hardware. Usability testing involves a sample of 10 to 15 participants and is treated as formative rather than statistically representative.

VI. Definition of Terms

FIDO2.

An open authentication standard developed by the FIDO Alliance and W3C. FIDO2 enables passwordless and phishing-resistant authentication using public-key cryptography, eliminating reliance on shared secrets transmitted across network channels.

Java Card.

A programmable smart card platform defined by Oracle that executes Java Card applets within a constrained, tamper-resistant environment. The platform isolates cryptographic operations and key storage from the host device through a dedicated Secure Element.

ECDSA P-256.

The Elliptic Curve Digital Signature Algorithm implemented using the NIST P-256 curve (secp256r1). This configuration provides 128-bit security strength, equivalent to a 3072-bit RSA key, within the constrained memory and computation budgets of smart card hardware.

NFC (Near Field Communication).

A short-range wireless communication protocol operating at 13.56 MHz over the ISO/IEC 14443 standard. NFC's proximity requirement of approximately four centimeters substantially limits passive eavesdropping compared to longer-range wireless protocols.

FIDO2-Compliant Applet.

A Java Card applet programmed to perform ECDSA P-256 key generation and challenge-response signing in accordance with the FIDO2/CTAP2 specification, enabling the card to function as a FIDO2 hardware authenticator.

CNN-LSTM.

A hybrid deep learning architecture combining a Convolutional Neural Network (CNN) for local feature extraction with a Long Short-Term Memory (LSTM) network for sequential dependency modeling. In this study it is applied to character-level URL classification for phishing detection.

STRIDE.

A threat modeling framework addressing six threat categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. STRIDE provides a structured method for identifying architectural vulnerabilities before implementation begins.

Secure Element (SE).

A dedicated, tamper-resistant microprocessor embedded in the Java Card that isolates sensitive key material and cryptographic operations from the card's external environment. Data within the SE can only be accessed through strictly defined Application Protocol Data Units (APDUs).

CHAPTER 2

REVIEW OF RELATED LITERATURE AND STUDIES

2.1 The Vulnerability of Digital Banking in the Modern Threat Landscape

Online banking has given attackers a larger, more accessible surface to work with. Threats that once required physical proximity, stolen documents, or insider access can now be executed remotely and at scale. Karim et al. (2024), in a systematic literature review published in IEEE Access, identified phishing, credential theft, and man-in-the-middle attacks as the dominant and fastest-growing vectors targeting financial authentication systems. Even institutions that have deployed MFA remain exposed when the authentication factors themselves transit vulnerable networks.

The structural weakness is the shared-secret model. When a bank sends an OTP over SMS, the code must travel through a network the bank does not control. Haruna et al. (2022) documented how this channel dependency enabled the Bangladesh Bank SWIFT attack of 2016: attackers did not crack cryptography; they exploited unencrypted data paths and weak third-party integrations to intercept and replay authentication materials. The lesson is not that MFA is wrong but that network-dependent MFA is insufficient against adversaries with the patience to target the channel rather than the endpoint.

The Philippine context reflects these global patterns at a local scale. Blancaflor et al. (2023) reviewed documented online banking fraud cases sourced from Philippine social media and found phishing websites and social engineering to be the dominant attack vectors used against Filipino consumers. The NPC (2023) documented this concretely in its investigation of unauthorized GCash transactions, where victims were directed to phishing sites impersonating banks or gambling platforms and deceived into disclosing their authentication credentials. The incidents demonstrate that user behavior under social engineering pressure remains a system-level vulnerability, not just an individual failure.

Internationally, Frazier (2025) noted that the banking sector continues to rank as the primary target of phishing campaigns and ransomware, with attackers increasingly using fraudulent SSL certificates and cloned login portals to capture credentials before users can

detect the deception. These findings collectively establish that static credentials and network-transmitted OTPs are not sufficient defenses against the adversarial tactics currently in active use.

2.2 The Philippines' Transition to Modern Authentication Standards

The Philippine government's response to rising digital financial fraud culminated in the Anti-Financial Account Scamming Act (AFASA), enacted in 2026. The legislation initiates the regulatory phase-out of SMS-based OTPs in favor of cryptographically grounded authentication protocols (Villar, 2026). The Bangko Sentral ng Pilipinas (BSP), working with regulatory counterparts, has recommended hardware tokens and Public Key Infrastructure-compliant authentication mechanisms for digital banking accounts (Ayson-Zales et al., n.d.).

These developments align with the global movement toward FIDO2 and WebAuthn. Georgiadis (2023) described FIDO2's core security property: the protocol generates unique public-private key pairs per registration and authenticates without transmitting any shared secret across the network. The server verifies a cryptographic signature; it never receives the private key. This architecture eliminates the network channel as an attack surface for credential theft.

For Philippine banks, the challenge is balancing regulatory compliance with the practical realities of cost and user accessibility. Hardware tokens meeting FIDO2 standards currently range from affordable to expensive depending on the vendor and form factor. The Java Card-based NFC authenticator proposed in this study is positioned as a cost-accessible implementation of FIDO2-compliant hardware authentication that can be produced and distributed at a fraction of the cost of branded security keys, while meeting the same cryptographic standards.

2.3 Limitations of Biometrics and Network-Dependent MFA

Biometric authentication has gained adoption in mobile banking partly because it feels secure and requires no additional hardware. These properties are real, but they are not the same as cryptographic security. Jindal et al. (2020) demonstrated that fingerprint readers can be defeated using gelatin replicas and that facial recognition systems can be bypassed with high-

resolution photographs. The attack surfaces are not theoretical; they are documented and reproducible.

A more fundamental problem is irreversibility. Ali and Al-Dabbagh (2026), in a systematic review of biometric authentication in mobile banking, found that biometric data, unlike passwords, cannot be changed once compromised. A user whose fingerprint template is stolen has no recovery path equivalent to a password reset. Additionally, the study found that biometric verification in mobile devices depends on the security of the device itself and its cloud synchronization functions, meaning a compromised operating environment can intercept biometric-derived tokens at the application layer rather than within a trusted hardware boundary.

Network-based OTPs carry parallel structural problems. Ali and Al-Dabbagh (2026) documented that OTPs transmitted via SMS are vulnerable to SIM swapping and SS7 protocol exploitation. Haruna et al. (2022) extended this analysis to show that the vulnerability is not confined to exotic attack scenarios: standard malware capable of SMS redirection is commercially available and has been deployed against banking customers at scale. The conclusion is that OTPs need hardware-backed cryptographic authentication, not simply a faster delivery channel.

2.4 FIDO2 and WebAuthn Standards

FIDO2 is a set of open authentication specifications jointly developed by the FIDO Alliance and the W3C, comprising the WebAuthn API and the Client to Authenticator Protocol (CTAP2). The standard uses asymmetric public-key cryptography: during registration, the authenticator generates a key pair and registers the public key with the relying party. During authentication, the relying party issues a challenge, the authenticator signs it with the private key, and the relying party verifies the signature against the stored public key. The private key never leaves the authenticator.

Georgiadis (2023) analyzed FIDO2's security properties across enterprise and consumer contexts and found that the protocol's phishing resistance derives directly from origin binding: the signed assertion includes the relying party's origin, so a signature generated for a phishing site cannot be replayed against the legitimate bank. Würsching et al. (2023)

identified adoption barriers including multi-device support and account delegation, but noted that physical hardware authenticators remain technically superior to software tokens for high-security contexts because the private key's security depends on the hardware boundary rather than the software environment.

Ghosh et al. (2024) implemented a FIDO2-compatible smart card for decentralized financial transactions and demonstrated that Java Card hardware paired with NFC, BLE, and USB interfaces can serve as a practical FIDO2 authenticator in real financial environments. Their work provides a direct technical precedent for the hardware design proposed in this study.

2.5 Java Card Technology and Secure Element Architecture

Smart card technology provides a constrained but highly secure execution environment. At the core of this architecture is the Secure Element, a dedicated microprocessor designed to isolate sensitive cryptographic operations and key material from the external environment. Rankl and Effing (2010) provide the foundational treatment of smart card hardware architecture, establishing that the SE restricts direct memory access and permits data interaction only through strictly defined Application Protocol Data Units (APDUs) governed by the card's operating system.

This isolation has a direct security consequence: even if the host device is fully compromised by malware, the private keys stored within the card's Secure Element cannot be extracted, copied, or bypassed through the host operating system. The cryptographic boundary is physical, not software-defined. Oracle (2023) documents the Java Card platform security architecture in detail, specifying how applets running within the JCRE (Java Card Runtime Environment) are isolated from each other and from the external environment through the card's firewall mechanism.

For this study, the relevant property is that the ECDSA P-256 private key generated during card registration never exists outside the SE. It is generated inside, it signs inside, and it stays inside. The signed assertion—not the key—is what the mobile application receives and forwards to the server for verification.

2.6 Elliptic Curve Digital Signature Algorithm (ECDSA P-256)

ECDSA is an asymmetric public-key signature algorithm based on the algebraic structure of elliptic curves over finite fields, standardized by NIST in the Digital Signature Standard (NIST, 2023). The P-256 curve provides 128 bits of security strength, mathematically equivalent to a 3072-bit RSA key. This high security-to-key-size ratio is decisive for smart card environments where computational power, memory, and bandwidth are all constrained.

Johnson, Menezes, and Vanstone (2001) provided the foundational academic treatment of ECDSA, establishing the security properties of the algorithm and the conditions under which those properties hold. The critical property for this application is that the signing operation produces a unique digital signature for each challenge without revealing information about the private key. The relying party verifies the signature using only the public key, which the server stores from the initial registration and which carries no exploitable information about the private key itself.

W3C (2023) specifies ECDSA P-256 as the required cryptographic suite for FIDO2 hardware authenticators, meaning this study's cryptographic choices are not only technically sound but standards-compliant by design.

2.7 Near Field Communication (NFC) in Cryptographic Hardware

NFC is a high-frequency, short-range wireless protocol operating at 13.56 MHz. It is built on the ISO/IEC 14443 standard originally designed for contactless smart cards (Madlmayr et al., 2008). The defining security property of NFC for authentication purposes is its proximity requirement: effective communication range is approximately four centimeters. This physical constraint substantially reduces the attack surface for passive eavesdropping compared to Bluetooth or Wi-Fi, which operate at ranges of ten meters or more.

In this system, NFC serves as the transport layer between the mobile application and the Java Card. During authentication, the application transmits a cryptographic challenge to the card over NFC, and the card returns the signed assertion over the same channel. The channel is short-range and session-specific; there is no persistent wireless connection for an attacker to intercept passively over extended time periods.

Ghosh et al. (2024) confirmed the practical feasibility of NFC as a FIDO2 transport interface in their smart card implementation, finding that the combination of Java Card cryptography with NFC communication meets the latency and reliability requirements of real authentication scenarios. Their implementation established that NFC-mediated challenge-response authentication is not only cryptographically sound but operationally practical.

2.8 AI-Driven Phishing Detection

Traditional phishing detection relies on blacklists and static rule-based filters. These approaches work against known threats but fail against novel campaigns, which is precisely the condition under which they matter most. The research consensus has moved toward machine learning-based detection, particularly approaches that can generalize from patterns in training data to previously unseen phishing URLs.

Gurung et al. (2023) compared a Random Forest classifier and a CNN-LSTM hybrid on phishing URL classification tasks. The CNN-LSTM model achieved 94.7% accuracy on the test dataset, substantially outperforming the Random Forest's 70% accuracy. The difference comes from the architecture: the CNN-LSTM processes character-level sequences and learns both local character patterns and longer sequential dependencies in URL structure, making it better suited to the adversarial context where attackers deliberately obfuscate URLs to evade lexical detection.

Al Saidat et al. (2024) surveyed NLP and deep learning approaches to SMS phishing detection and found that models processing sequential input—CNNs, RNNs, and their hybrids—consistently outperform feature-engineered classifiers on novel phishing patterns. Their findings are consistent with the URL classification literature and support the selection of CNN-LSTM as the preferred architecture for the threat detection module in this study.

SSL/TLS certificate validation is the complementary detection mechanism for MiTM attacks. Certificate pinning, where the application validates the server's certificate against a known-good pin rather than the general certificate authority chain, detects cases where an attacker has inserted a fraudulent certificate into the connection. Together, URL classification and certificate validation address both the social engineering vector (phishing sites) and the protocol-level vector (MiTM interception).

2.9 Synthesis of the Review

The literature reviewed in this chapter establishes the theoretical and empirical basis for the dual-layered system proposed in this study. The failure mode of current MFA is well-documented: SMS and email-based OTPs transmit shared secrets over channels that adversaries can intercept, and biometric authentication moves the security boundary to the host device rather than an isolated hardware element. Both approaches leave exploitable gaps.

FIDO2-compliant hardware authentication with a Java Card Secure Element addresses the structural problem directly: authentication factors that never leave a tamper-resistant hardware boundary cannot be intercepted over a network. AI-driven phishing and certificate detection addresses the social engineering vector that hardware authentication alone does not cover: a user who visits a legitimate-looking phishing site and taps a legitimate Java Card has still been deceived. The threat detection module intercepts that deception before the user submits credentials.

Together, these two layers correspond to the two primary attack surfaces documented in the literature: credential interception at the protocol layer and social engineering at the application layer. The proposed system is the first implementation, to the knowledge of the researchers, that combines both defenses in a single cost-accessible prototype aligned with the Philippine regulatory context established by AFASA.

CHAPTER 3

METHODOLOGY

3.1 Research Design

This study uses a design and development research approach. The methodology follows a structured prototyping cycle in which requirements, design decisions, and security specifications are defined before implementation, tested iteratively during development, and validated against documented threat scenarios after integration. This approach is appropriate for research that produces a functional artifact with measurable security and usability properties rather than generating statistical data from a pre-existing system.

The dual-layered prototype integrates three component tracks that are developed in parallel and tested both independently and as a unified system: the Java Card hardware authentication layer, the Flutter mobile application layer, and the Firebase cloud backend layer. Each track produces testable outputs at defined milestones, and integration testing is conducted incrementally to catch interface failures before full-system validation.

3.2 Multiple Design Constraints, Trade-offs, and Standards

3.2.1 Design Constraints

The system operates under several binding constraints that shaped design decisions throughout development.

Hardware constraints are imposed by the Java Card platform itself. The Feitian FT-JCOS A40CR card has limited RAM (approximately 4 KB), EEPROM (64 KB), and computational throughput compared to general-purpose hardware. ECDSA P-256 operations are performant on the card's crypto-coprocessor, but the applet design must minimize data exchanges and avoid operations that would exceed the card's timing budget during an authentication event.

Communication constraints are imposed by NFC. The ISO/IEC 14443 standard specifies a maximum data rate of 848 kbps in the highest transmission mode, with practical throughput lower under real-world conditions. NFC frames are limited in size, and the

authentication protocol must fit within these constraints without requiring fragmentation that would increase latency or introduce error conditions.

Platform constraints limit the mobile application to NFC-capable Android devices. The Flutter application targets Android API Level 24 and above, which covers the NFC Host Card Emulation and reader mode APIs required for card communication. iOS is excluded from the current prototype due to CoreNFC restrictions on APDU command transmission in reader mode.

Regulatory constraints are imposed by AFASA and BSP guidelines, which require that any authentication system proposed for financial applications meet or exceed the security standards of the OTP mechanisms they replace. The FIDO2 standard is explicitly recognized as compliant with this requirement.

3.2.2 Design Trade-offs

Several design decisions involved explicit trade-offs between competing properties.

Security versus convenience: hardware-based authentication adds a physical step to the login process—the user must tap the card. This reduces the attack surface significantly but adds friction compared to a biometric swipe or SMS code entry. The design addresses this by making the tap gesture the only additional step after password entry, and by providing clear on-screen prompts that guide users through the interaction.

Model accuracy versus latency in the phishing detector: larger, more accurate deep learning models require more time to produce a classification result. The CNN-LSTM architecture was selected as a balance point—it achieves higher accuracy than classical classifiers on character-level URL data while remaining deployable on mobile hardware within the 500 ms latency threshold defined for acceptable real-time performance.

Custom protocol versus FIDO2 compliance: an earlier version of the proposal considered a custom challenge-response protocol. This was explicitly rejected in the final design. FIDO2 is a well-analyzed, publicly standardized protocol with known security properties. A custom protocol would require independent security analysis to establish equivalent assurance, introducing implementation risk without corresponding benefit. The final design implements FIDO2/CTAP2 compliance as a non-negotiable requirement.

3.2.3 Standards Compliance

The system is designed to comply with the following standards and specifications:

- IEEE 2600 Series: Security requirements for hard-copy devices, referenced for Secure Element access control patterns.
- FIDO2/CTAP2 Specification: Defines the authenticator behavior, key generation requirements, and challenge-response protocol implemented by the Java Card applet.
- ISO/IEC 14443: Contactless smart card communication standard governing NFC transport layer behavior.
- NIST FIPS 186-5: Digital Signature Standard specifying ECDSA P-256 security parameters and implementation requirements.
- GlobalPlatform Card Specification 2.3: Governing the secure applet installation and lifecycle management on the Java Card.
- Common Criteria EAL4+: The target assurance level for the hardware Secure Element; the Feitian FT-JCOS platform is certified at this level.

3.3 Conceptual Framework

The system is organized into three functional layers that interact to produce a secure, dual-layered authentication experience.

The hardware layer consists of the Feitian FT-JCOS Java Card (A40CR) with its embedded Secure Element and NFC interface. The SE generates and permanently stores the ECDSA P-256 private key during registration. During authentication, it receives challenges via NFC APDU commands and returns signed assertions without the private key leaving the hardware boundary. The NFC interface operates at 13.56 MHz per ISO/IEC 14443.

The application layer is the Flutter/Dart mobile application running on an NFC-capable Android device. It contains three functional modules: the NFC authentication module manages the challenge relay and signature return flow with the Java Card; the threat detection module runs the trained CNN-LSTM URL classifier and evaluates SSL/TLS certificate validity in real time during banking sessions; and the Firebase integration module handles user registration, session management, and challenge generation requests to the backend.

The backend layer is Firebase cloud services. Firebase Authentication manages user credentials and session tokens. Firestore stores user profiles and the public keys registered during card enrollment. Cloud Functions execute signature verification logic—they receive the signed challenge and the user's registered public key, verify the ECDSA signature, and return an authentication grant or rejection.

Data flow during authentication proceeds as follows: the user initiates login in the mobile application; the application requests a one-time challenge from Firebase; Firebase generates and returns the challenge; the application prompts the user to tap the Java Card; the NFC module transmits the challenge to the card via APDU; the card's SE signs the challenge using the private key; the signed assertion returns to the application; the application forwards the assertion to Firebase; the Cloud Function verifies the signature against the registered public key; and Firebase grants or rejects the session. Concurrently, the CNN-LSTM module monitors all URLs encountered during the session and surfaces an alert if the phishing probability score exceeds the classification threshold.

3.4 Technical Design and Procedure

3.4.1 Research Methodology

Development is organized into four sequential phases, each with defined inputs, outputs, and validation criteria.

Requirements Phase.

This phase identifies the functional and non-functional requirements of the complete system through literature analysis, examination of existing authentication vulnerabilities, and alignment with AFASA regulatory requirements. Functional requirements include: FIDO2-compliant NFC authentication between the Feitian FT-JCOS A40CR card and an Android device, ECDSA P-256 cryptographic challenge-response signing, real-time phishing URL classification within the mobile application, SSL/TLS certificate validation with user-facing alerts, and user account management through Firebase. Non-functional requirements include: system resistance to all six STRIDE threat categories, NFC communication latency within acceptable bounds for user experience, CNN-LSTM classifier accuracy above 90% with false

positive rate below 5%, and usability for non-technical banking users as measured by the System Usability Scale.

Design Phase.

Design translates the gathered requirements into a concrete system architecture. The architecture is organized into the three layers described in the conceptual framework: hardware, application, and backend. At this phase, the STRIDE threat model is applied to the data flow diagram before development begins. Each component is analyzed for Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege threats, and architectural controls are specified for each identified threat. The CNN-LSTM model architecture, training dataset selection, and deployment configuration are finalized in this phase. UI flow for the tap-to-authenticate interaction and the phishing alert interface is designed using Figma prototypes and reviewed for clarity before implementation.

Development and Integration Phase.

Development proceeds on three parallel tracks. On the hardware track, the Feitian FT-JCOS A40CR is configured with a FIDO2-compliant applet capable of ECDSA P-256 key generation and NFC challenge-response signing. The applet is loaded using GlobalPlatform-compliant tools and tested for correct cryptographic output against known test vectors before integration. On the mobile application track, the Flutter/Dart application is developed with the three core modules described in the conceptual framework. The CNN-LSTM model is trained on the PhishTank and UCI phishing datasets and optimized for on-device deployment within the 500 ms latency threshold. On the backend track, Firebase is configured with authentication rules, a Firestore database structure for user and public key storage, and Cloud Functions for challenge generation and ECDSA signature verification. Integration testing validates NFC communication first, then end-to-end authentication flow with the Firebase backend, then the live integration of the threat detection module into active banking sessions.

Testing and Validation Phase.

Testing covers four domains: functional testing validates that each component performs its specified operation under normal and edge-case conditions; security testing applies STRIDE-based attack simulations to verify the architectural controls are effective; ML

performance testing evaluates the CNN-LSTM classifier on held-out test data with accuracy, precision, recall, F1-score, and latency measurements; and usability testing assesses the NFC tap-to-authenticate interaction with a participant group using task timing, error logging, and SUS questionnaire scoring.

3.4.2 Software Design

The software design of the proposed system is presented using the Input-Process-Output (IPO) model. The system is organized into three functional modules.

Module 1: Hardware Authentication Module.

This module handles the core cryptographic exchange for user login. When a login event begins, the Firebase backend generates a one-time cryptographic challenge unique to that session. The mobile application transmits this challenge to the FIDO2 Java Card via NFC. The card's Secure Element signs the challenge using the private key and returns the signed assertion via NFC. The application forwards the assertion to a Firebase Cloud Function, which verifies the ECDSA P-256 signature against the registered public key stored in Firestore. A matching signature grants the session; a mismatch rejects it.

Module 2: Phishing Detection Module.

This module runs in the background throughout the banking session. As the user navigates within the application, every URL encountered is extracted, tokenized into a character-level sequence, and passed to the CNN-LSTM classifier. The classifier returns a phishing probability score between 0 and 1. If the score exceeds the classification threshold—determined during model validation—the application displays a full-screen alert warning the user that the site has been classified as potentially malicious, blocking credential entry until the user explicitly dismisses or proceeds. SSL/TLS certificate validation runs in parallel: self-signed, expired, or certificate-pinning-violating certificates trigger a separate alert class indicating a potential MiTM condition.

Module 3: User Management Module.

This module manages user registration and hardware binding. The registration flow creates a new user account in Firebase Authentication and assigns a unique user ID. The

application then prompts the user to tap their Java Card, which triggers ECDSA P-256 key pair generation within the Secure Element. The generated public key is transmitted to the application via NFC and stored in Firestore linked to the user's account. The private key remains permanently inside the card and is never transmitted. All subsequent authentications use this registered public key for signature verification.

3.4.3 UI Design

The user interface is designed in Figma and implemented in Flutter using Material Design 3 components. The interface presents three primary interaction states: the login screen, which prompts for email and password then transitions to the NFC tap prompt; the NFC tap screen, which provides visual and haptic feedback during card scanning; and the threat alert screen, which displays a full-screen warning with threat classification detail when the phishing detector flags a URL or certificate anomaly.

Design decisions throughout the interface prioritize clarity of the security state. The NFC tap prompt uses a single animated icon and brief instructional text to minimize cognitive load during the authentication step. The threat alert screen uses high-contrast warning colors and unambiguous language, avoiding technical jargon in the user-facing message while logging full technical detail to the application's diagnostic output.

3.5 Data Collection and Treatment

3.5.1 Data Collection

This study collects data across four categories corresponding to the four development phases: hardware authentication performance, AI threat detection performance, NFC connectivity and usability, and STRIDE threat modeling evaluation. All participant data is collected with informed consent. No personally identifiable information beyond what is necessary to differentiate participant sessions is retained. No testing takes place on live banking systems; all transaction scenarios are simulated in controlled environments using synthetic data.

Hardware Authentication Performance Data.

The Java Card's authentication performance is measured through controlled testing with NFC-capable Android devices. Each test run transmits a unique random challenge to the card and records the time from NFC challenge transmission to application receipt of the signed assertion, the success or failure of ECDSA signature verification against the registered public key, and any error conditions encountered. Each device-scenario combination is tested a minimum of 30 times to produce statistically stable latency measurements. Key non-exportability is verified by attempting private key extraction operations through both APDU command sequences and side-channel analysis; any successful extraction would constitute a critical failure requiring immediate design revision.

AI Threat Detection Performance Data.

The CNN-LSTM phishing classifier is evaluated on a held-out test split of the combined PhishTank and UCI phishing datasets, with a balanced proportion of malicious and legitimate URLs. Performance metrics recorded include classification accuracy, precision, recall (true positive rate), F1-score, and false positive rate. Detection latency is measured from URL input to classifier output across the full test set. SSL/TLS anomaly detection is evaluated separately across four scenario types: self-signed certificates, expired certificates, certificate pinning violations, and valid certificates. The correct-alert rate for each scenario type is reported separately because different anomaly types involve different detection mechanisms.

NFC Connectivity and Usability Data.

A mid-fidelity prototype is used during usability sessions with a target group of 10 to 15 participants drawn from adults with no prior exposure to hardware security keys. Participants are observed completing a login task first without instruction, then with a brief orientation. Data collected includes task completion time from initial prompt to confirmed login, NFC first-tap success rate, user error incidents classified by type, and SUS questionnaire scores following task completion. Error incidents occurring in more than 20% of sessions are flagged as design revision targets for the UI or physical form factor.

STRIDE Threat Modeling Evaluation Data.

Structured evaluation sessions are conducted to test the system's resistance to each of the six STRIDE threat categories. Specific attack scenarios are defined for each category based

on the threat analysis performed during the design phase: spoofing scenarios include forged card identity attempts and server impersonation; tampering scenarios include NFC data modification and Firestore record manipulation; repudiation scenarios test the completeness and integrity of authentication logs; information disclosure scenarios include NFC eavesdropping and Firestore data exposure; denial of service scenarios test card and server behavior under sustained authentication request loads; and privilege escalation scenarios test for unauthorized access to higher-privilege application functions. Outcomes are documented in a STRIDE matrix table.

3.5.2 Data Treatment

Authentication Performance Analysis.

Authentication latency measurements are recorded in milliseconds. Mean, median, and standard deviation are computed across all test runs per device. Outlier runs remain in the dataset but are flagged with cause annotations to preserve transparency. Authentication success rates are expressed as percentages of valid responses over total attempts. Failure logs are classified by failure type and tabulated to identify recurring patterns that indicate design issues rather than isolated hardware variability.

AI Model Evaluation.

The classifier's outputs are evaluated against ground-truth labels using a confusion matrix. Accuracy, precision, recall, F1-score, and false positive rate are computed from the confusion matrix. F1-score is the primary summary metric because it balances precision and recall—a model that classifies everything as benign achieves high accuracy but fails on F1. Detection latency is treated as a pass/fail threshold metric: any model configuration that exceeds 500 ms mean latency is flagged for optimization before final integration. SSL/TLS anomaly detection results are reported per scenario type rather than as a single aggregate, because the detection mechanism differs per anomaly class.

Usability and NFC Connectivity Analysis.

SUS scores are computed using the standard scoring formula (item scores summed and multiplied by 2.5, yielding a score out of 100). Scores at or above 68 are considered acceptable usability for this interaction type. Task completion times are averaged across participants.

First-tap NFC success rates are expressed as percentages. Error incidents are classified by type and frequency, with those occurring in more than 20% of sessions flagged as design revision targets. All usability data is treated as formative, used to inform design improvements rather than as pass/fail judgments.

STRIDE Matrix Analysis.

STRIDE evaluation outcomes are documented in a structured matrix with each threat category as a row and each tested scenario as a column. Mitigation status is recorded using a three-level scale: Mitigated (the existing design fully addresses the threat), Partially Mitigated (the design reduces but does not eliminate the threat), and Not Mitigated (no current control addresses the threat). Partially Mitigated and Not Mitigated entries are accompanied by specific recommendations for addressing the remaining gap.

3.6 System Testing and Evaluation

3.6.1 Functional Testing

Functional testing validates that each component performs its specified operation under both normal and edge-case conditions. Test cases cover four functional areas.

Java Card applet testing verifies: key pair generation produces a valid ECDSA P-256 key pair; the private key cannot be read via any APDU command sequence; signed assertions produced by the card verify correctly against the registered public key; the card responds correctly to malformed or truncated challenge inputs; and card behavior is consistent across repeated authentication events.

NFC communication testing verifies: the application detects the card's presence within the expected range; challenge transmission and assertion reception complete without data corruption; the communication fails gracefully when the card is removed mid-transaction; and authentication correctly rejects an unsigned or incorrectly signed assertion.

Firebase backend testing verifies: challenge generation produces unique values for each session; signature verification correctly grants sessions for valid signatures and rejects them for invalid or replayed signatures; public key storage and retrieval operate correctly; and session tokens expire after the configured duration.

Mobile application testing verifies: all authentication state transitions (pending, success, failure, timeout) are handled correctly and reflected accurately in the UI; the threat detection module fires alerts for known-malicious URLs in the test dataset and does not fire alerts for known-benign URLs; SSL/TLS anomaly alerts fire for each defined anomaly scenario; and the application handles NFC communication failures without crashing.

3.6.2 Security Testing

Security testing applies STRIDE-based attack scenarios to the implemented prototype. Table 3.1 documents the threat scenarios tested, the system layer each scenario targets, and the mitigation status determined through testing.

Threat	Test Scenario	Layer	Status	Control / Gap
Spoofing	Forged card identity via replay of captured APDU response	Hardware	**Mitigated**	Challenge is unique per session; replayed assertions fail verification
Spoofing	Server impersonation via fraudulent SSL certificate	Application	**Mitigated**	Certificate pinning triggers MiTM alert before credentials are submitted
Tampering	NFC data modification between card and phone	Hardware	**Mitigated**	ECDSA signature invalidated by any bit-level modification of the assertion
Tampering	Firestore public key substitution by unauthorized write	Backend	**Partially Mitigated**	Firebase security rules restrict writes; key rotation procedure not yet implemented
Repudiation	User denies completing authentication event	Backend	**Mitigated**	Signed assertion with session timestamp provides cryptographic non-repudiation
Info. Disclosure	NFC passive eavesdropping of challenge/assertion exchange	Hardware	**Mitigated**	Eavesdropped assertion cannot be reused; private key not transmitted
Info. Disclosure	Firestore user data unauthorized read	Backend	**Mitigated**	Firebase security rules restrict reads to authenticated session owner
Denial of Service	Sustained authentication request flood to Firebase	Backend	**Partially Mitigated**	Firebase rate limiting applies; additional

Threat	Test Scenario	Layer	Status	Control / Gap
				server-side throttle not implemented
Denial of Service	Card unresponsive after protocol error injection	Hardware	**Mitigated**	Card OS resets APDU state on error; re-tap initiates clean transaction
Elevation of Privilege	Unauthorized access to admin Firebase functions	Backend	**Mitigated**	Admin functions protected by service account credentials not exposed to client
Elevation of Privilege	Application privilege escalation via malicious URL injection	Application	**Mitigated**	CNN-LSTM classifier blocks navigation to malicious URLs before content loads

Table 3.1. STRIDE Threat Resistance Matrix for the Dual-Layered Authentication Prototype.

3.6.3 Machine Learning Performance Testing

The CNN-LSTM phishing detection model is evaluated on a held-out test split comprising 20% of the combined PhishTank and UCI phishing dataset. The test split is stratified to maintain the same malicious-to-benign ratio as the full dataset. Performance is reported across the following metrics: accuracy (proportion of correctly classified instances), precision (proportion of malicious predictions that are actually malicious), recall (proportion of actual malicious URLs that are correctly flagged), F1-score (harmonic mean of precision and recall), false positive rate (proportion of legitimate URLs incorrectly flagged), and mean classification latency.

The 500 ms latency threshold is defined based on user experience research establishing that delays beyond this threshold are perceptible as application lag. Any model configuration exceeding this threshold is subject to optimization, including quantization, input sequence truncation, or architectural reduction, before final integration into the mobile application.

SSL/TLS anomaly detection performance is reported as correct-alert rate per scenario type: self-signed certificate, expired certificate, certificate pinning violation, and valid certificate. Results for each anomaly type are reported separately rather than aggregated, because the detection mechanism and failure mode differ across anomaly types.

3.6.4 Usability Testing

Usability testing is conducted with a target sample of 10 to 15 adult participants who have no prior experience with hardware security keys or NFC-based authentication. Participants are drawn from the university community and stratified by familiarity with mobile banking applications.

Each session follows a standardized protocol: the participant is given the prototype application and Java Card and asked to complete a login task without any instruction. The facilitator records task completion time, NFC tap attempts required, and any error incidents. After the unaided attempt, the facilitator provides a brief orientation (approximately one minute) and the participant repeats the task. Post-task, participants complete the SUS questionnaire. The session concludes with a brief open-ended interview to capture qualitative observations about the interaction.

SUS scores at or above 68 indicate acceptable usability. Scores below this threshold trigger design revision of the tap interaction flow, on-screen prompts, or physical card form factor guidance. Task completion times, first-tap success rates, and error incident frequencies are reported as descriptive statistics across the participant group.

3.7 Ethical Considerations

All human participants in usability testing are adults who provided written informed consent before participation. Participants are informed of the study's purpose, the voluntary nature of their participation, and their right to withdraw at any time without consequence. No personally identifiable information beyond what is necessary to differentiate participant sessions is collected or retained.

All participant data is stored on password-protected devices accessible only to the research team. Session observation notes and SUS questionnaire responses are anonymized during analysis. All participant data is deleted upon completion of analysis and before the study is submitted for review.

No testing takes place on live banking systems or involves real financial accounts at any point. All authentication scenarios use simulated transaction data in controlled environments. Phishing URL datasets sourced from PhishTank and OpenPhish are used strictly for model training and evaluation and are not redistributed beyond the duration of the study.

REFERENCES

Ali, H. N., & AL-Dabbagh, S. S. M. (2026). A systematic literature review on biometric authentication in mobile banking. F1000Research, 15–5, 1–41. https://doi.org/10.12688/f1000research.173855.1

Al Saidat, M. R., Yerima, S. Y., & Shaalan, K. (2024). Advancements of SMS spam detection: A comprehensive survey of NLP and ML techniques. Procedia Computer Science, 244, 248–259. https://doi.org/10.1016/j.procs.2024.10.198

Ayson-Zales, J. G., Tomas, R. D., Mesina-Romero, B. R. M., Contreras, M. R. A., Regis, A. B. G., Asiddao-Alcantara, A. M., Salud, M. A., Baylon, P. K. J., Ferrer-Magtuba, F. A. P., Prado, C. M. S., Defante-Andres, T. T., Irao, L. M., Ramos, A. S., Matias, J. E. L., Perez, A. B. S., Geraldez-Silva, P. P., Angeles, R. A. C., Macatangay, D. C., Pascual, A. P. P., & Santillan, K. U. (n.d.). Anti-Financial Account Scamming Act. Bangko Sentral ng Pilipinas. https://www.bsp.gov.ph/Regulations/Banking%20Laws/AFASA-Booklet-with-IRRs.pdf

Blancaflor, E., Cruz, R. G. D., Federez, U. A., & Samonte, D. (2023). Social media content compilation of online banking scams in the Philippines: A literature review. Proceedings of the 2023 14th International Conference on E-Education, E-Business, E-Management and E-Learning, 236–242. https://doi.org/10.1145/3588243.3588284

Darem, A. A., Alhashmi, A. A., Alkhaldi, T. M., Alashjaee, A. M., Alanazi, S. M., & Ebad, S. A. (2023). Cyber threats classifications and countermeasures in banking and financial sector. IEEE Access, 11, 125138–125158. https://doi.org/10.1109/ACCESS.2023.3327685

Frazier, E. (2025, December 10). Exploring the technology behind NFC cards. Jaycon. https://www.jaycon.com/exploring-the-technology-behind-nfc-cards/

Georgiadis, E. (2023, February). FIDO2 overview, use cases, and security considerations. ResearchGate. https://www.researchgate.net/publication/370750978_FIDO2_Overview_Use_Cases_and_Security_Considerations

Ghosh, A., Mitra, A., Sethuraman, S. C., & Cherukuri, A. K. (2024). Conceptual design and implementation of FIDO2 compatible smart card for decentralized financial transaction system. arXiv. https://arxiv.org/abs/2408.04977

Gurung, S., Bhattarai, S., Acharya, B., & Adhikari, B. (2023). Phishing URL detection using machine learning and deep learning. International Journal of Advanced Computer Science and Applications, 14(8). https://doi.org/10.14569/IJACSA.2023.0140856

Haruna, W., Aremu, T. A., & Modupe, Y. A. (2022). Defending against cybersecurity threats to the payments and banking system. arXiv. https://arxiv.org/abs/2212.12307

Jindal, R., Malhotra, C., & Bhatia, A. (2020). Techniques for biometric system: A review. International Journal of Advanced Research in Computer Science, 11(3), 1–7.

Johnson, D., Menezes, A., & Vanstone, S. (2001). The Elliptic Curve Digital Signature Algorithm (ECDSA). International Journal of Information Security, 1(1), 36–63.

Karim, N. A., Khashan, O. A., Kanaker, H., Abdulraheem, W. K., Alshinwan, M., & Al-Banna, A.-K. (2024). Online banking user authentication methods: A systematic literature review. IEEE Access, 12, 741–757. https://doi.org/10.1109/access.2023.3346045

Krishna Prakasha, K., & Sumalatha, U. (2025). Privacy-preserving techniques in biometric systems: Approaches and challenges. IEEE Access, 13, 32584–32616. https://doi.org/10.1109/ACCESS.2025.3541649

Madlmayr, G., Langer, J., Kantner, C., & Scharinger, J. (2008). NFC devices: Security and privacy. Proceedings of the 3rd International Conference on Availability, Reliability and Security.

National Institute of Standards and Technology. (2023). Digital Signature Standard (DSS) (FIPS PUB 186-5). U.S. Department of Commerce. https://doi.org/10.6028/NIST.FIPS.186-5

NPC Concludes Investigation on Unauthorized GCash Transactions. (2023, May 24). [Press release]. National Privacy Commission. https://privacy.gov.ph/npc-concludes-investigation-on-unauthorized-gcash-transactions/

Oracle. (2023). Java Card platform security architecture and cryptography specification. Oracle Corporation.

Rankl, W., & Effing, W. (2010). Smart Card Handbook (4th ed.). Wiley.

Stallings, W. (2023). Cryptography and network security: Principles and practice (9th ed.). Pearson.

Sureka, A., Mondkar, R., & Nandagopal, S. (2023). U.S. Patent No. 11,605,083. U.S. Patent and Trademark Office.

Villar, J. (2026, March 17). Villar welcomes phasing out of SMS OTPs, bats for strengthened security of digital transactions under AFASA Law. [Press release]. Senate of the Philippines.

World Wide Web Consortium (W3C). (2023). Data Integrity ECDSA Cryptosuites v1.0. W3C Candidate Recommendation. https://www.w3.org/TR/vc-di-ecdsa/

Würsching, T., Putz, F., Haesler, S., & Hollick, M. (2023). FIDO2 the rescue? Platform vs. roaming authentication on smartphones. Proceedings of the 2023 CHI Conference on Human Factors in Computing Systems. https://doi.org/10.1145/3544548.3581526